



WINTER 2026

DATA BREACHES

ASSIGNMENT #1

MATTHEW BOUTILIER

W0498901

ISEC 3078: Incidence Handling & Response

TABLE OF CONTENTS

1. Hospital Breach As The Result Of A Hack	2
1.1. Head of The Public Body	2
1.2. Custodian	2
1.3. Monitoring User Activity on Electronic Information Systems	2
1.4. Requirements For Safeguarding Health INformation	3
1.5. Authority & Criteria for Breach Notification(s)	3
1.6. Notification Procedures and Timeline(s)	4
1.6A. Who Must Be Notified.....	4
1.6B. When Must They Be Notified	4
1.7. Employee Penalties for Malicious Disclosure	4
2. Storage of Information Outside of Canada.....	5
2.1. Head Of The Public Body	5
2.2. Authority For Storage Of Public Data Internationally	5
2.3. Minister Notification of Internation Data Storage	5
2.4. Corporate & Individual Penalties for Service Providers	6
2.4A. Service Provider as a Corporation	6
2.4B. Officer of the Provider	6
2.5. Legal Justification(s) for charging service providers	6
References.....	7
Appendix I	9
Note.....	9
Appendix II	10
Appendix III	11
Appendix IV	13
Appendix V.....	14
Appendix VI.....	16
Appendix VII.....	17

1. HOSPITAL BREACH AS THE RESULT OF A HACK

1.1. HEAD OF THE PUBLIC BODY

Under the Freedom of Information and Protection of Privacy Act, the definition of a head depends on the specific type of public body involved. For a local public body such as a hospital, Section 3(1)(c) and Section 3(1)(c)(iia) of the Act define the head as the person or group of people designated by the body itself, typically the CEO, President, or Board Chairperson.

Section 49A of the Act explicitly requires the hospital to make this designation through by-law implementation or another legally valid method. This formal process allows the organization to identify clearly who holds the authority and legal accountability for legal purposes.

1.2. CUSTODIAN

The custodian in this scenario is the hospital itself, which is legally recognized as a health authority separate from the Nova Scotia Health Authority. Section 3(f) and Section 3(f)(iv) of the Personal Health Information Act define a custodian as the individual or organization that has custody or control of personal health information, and it specifically lists a health authority as a primary example of this role.

Section 2(1)(o) of the Health Authorities Act clarifies this definition by stating that a health authority refers to the provincial health authority or the IWK Health Centre. Because of these specific legal definitions, the hospital bears the legal responsibilities of a custodian for all the health data involved in the breach.

1.3. MONITORING USER ACTIVITY ON ELECTRONIC INFORMATION SYSTEMS

Section 63, subsections (1) to (5) of the Personal Health Information Act state that the custodian must create and maintain a record of user activity for any electronic system used to manage personal health information. These records can be generated manually or electronically, and the custodian is required to audit them regularly to detect and investigate any potential privacy breaches.

According to Section 11(1), Section 11(2), subsections (a) to (f), and Section 11(3) of the Personal Health Information Regulations, these records must contain specific details such as the names and IDs of both the user(s) and the patient, the date and time of the access, and a description of the data accessed. The custodian is also required to keep this information on file for at least one year after each instance of access to ensure a proper trail exists.

1.4. REQUIREMENTS FOR SAFEGUARDING HEALTH INFORMATION

Section 61(1), subsections (a) to (c) of the Personal Health Information Act require the custodian to implement information practices that are reasonable in the many circumstances. These practices must protect data against theft, loss, and unauthorized access or modification. Because the hospital uses an electronic system, Section 65 triggers extra security requirements that the hospital is legally obligated to follow.

Section 10, subsections (1) to (4) of the Personal Health Information Regulations specify that the custodian must safeguard network infrastructure and protect hardware to restrict access to authorized users only. Additionally, the custodian must maintain written policies to enforce these safeguards and keep a record of any security breach that poses a risk, including details on the corrective steps taken to fix the issue.

1.5. AUTHORITY & CRITERIA FOR BREACH NOTIFICATION(S)

The responsibility for deciding whether notification is required is with the custodian. Under Section 63, subsections (1) to (5) and Section 69 of the Personal Health Information Act, the custodian must notify the affected individual if they believe the information was stolen, lost, or accessed without authorization. This step is especially important if the custodian believes the breach could cause harm or embarrassment to the person involved.

However, Section 70, subsections (1) to (2) of the Personal Health Information Act allow for exceptions if the custodian determines that a breach is unlikely to have occurred or that there is no real potential for harm. In cases where the custodian decides not to notify the individual, they are legally obligated to notify the Review Officer of this decision as soon as possible.

1.6. NOTIFICATION PROCEDURES AND TIMELINE(S)

1.6A. WHO MUST BE NOTIFIED

If the conditions for notification are met, Section 69 of the Personal Health Information Act requires the custodian to notify the specific individual that the health information relates to. The primary focus of this rule is to alert the patient whose privacy was compromised so they are aware of the situation and can take any necessary precautions.

1.6B. WHEN MUST THEY BE NOTIFIED

Section 69 of the Personal Health Information Act also stipulates that this notification must be provided at the first reasonable opportunity. This ensures the individual is made aware of the breach promptly after the custodian determines the information was compromised and that a potential risk of harm or embarrassment exists.

1.7. EMPLOYEE PENALTIES FOR MALICIOUS DISCLOSURE

If it is proven that the employee participated in the hack, they face penalties under specific provincial laws. Under Section 107 of the Personal Health Information Act, any individual guilty of an offense such as unauthorized access or disclosure is liable to a fine of not more than \$10,000, imprisonment for six months, or both.

Because the scenario implies malicious intent, the Personal Information International Disclosure Protection Act also applies. Section 12 of the Personal Information International Disclosure Protection Act states that any employee who maliciously discloses personal information is guilty of an additional offense and could face a fine of not more than \$2,000, imprisonment for six months, or both.

2. STORAGE OF INFORMATION OUTSIDE OF CANADA

2.1. HEAD OF THE PUBLIC BODY

Under Section 2(1)(e) of the Personal Information International Disclosure Protection Act, the head of a public body that is a municipality is defined as the responsible officer as defined by the Municipal Government Act. This ensures that the leadership roles for privacy and municipal governance are clearly linked across provincial laws.

Section 461(i)(i) of the Municipal Government Act further clarifies this by stating that for a regional municipality, town, or county, the responsible officer is the chief administrative officer. If no chief administrative officer has been appointed, the responsibility falls to the clerk to fulfill the duties of the head for that public body.

2.2. AUTHORITY FOR STORAGE OF PUBLIC DATA INTERNATIONALLY

The municipality is permitted to store this data outside of Canada under specific legal exceptions. While the general rule under Section 5(1)(c) of the Personal Information International Disclosure Protection Act requires that personal information be stored and accessed only in Canada, the head of the public body has the authority to make exceptions.

The head may allow for storage or access outside of the country if they determine it is necessary to meet the requirements of the public body's operation. This allows municipalities the flexibility to use international services as long as the head of the body formally decides that the operational need justifies the move.

2.3. MINISTER NOTIFICATION OF INTERNATIONAL DATA STORAGE

The last possible date to inform the Minister of this decision is March 31, 2027. Section 5(3) of the Personal Information International Disclosure Protection Act requires the head of a public body to report such a decision to the Minister within a specific timeframe after the end of the year.

Specifically, the report must be submitted within ninety days after the end of the calendar year in which the decision was made. Since this decision was made in 2026, the ninety-day period begins after December 31, 2026, which places the final legal deadline on the last day of March in 2027.

2.4. CORPORATE & INDIVIDUAL PENALTIES FOR SERVICE PROVIDERS

2.4A. SERVICE PROVIDER AS A CORPORATION

For a service provider that is a corporation, Section 13(3)(c) of the Personal Information International Disclosure Protection Act establishes a maximum fine of \$500,000 for offenses under the Act. This significant penalty is designed to ensure that corporations handling public sector data adhere strictly to privacy requirements.

2.4B. OFFICER OF THE PROVIDER

For an individual officer of the provider, Section 13(3)(b) sets the maximum fine at \$25,000. It is important to note that while Section 12 of the Personal Information International Disclosure Protection Act includes potential jail sentences for public body employees, there is no corresponding jail sentence listed for service providers or their associates under Section 13.

2.5. LEGAL JUSTIFICATION(S) FOR CHARGING SERVICE PROVIDERS

There is a limitation on charging providers, the provider and its officers can still be charged even though the initial act took place in January 2026. Section 13(4)(b) of the Personal Information International Disclosure Protection Act provides a limitation period for starting a prosecution that depends on when the Minister became aware of the violation.

The law allows for a prosecution to commence up to one year after the date on which the Minister learned of the act, provided that date is later than the actual occurrence. Because the Minister was informed in March 2027, the window for legal liability remains open until March 2028, making both the corporation and its officers eligible for charges until that time.

REFERENCES

- Freedom of Information and Protection of Privacy Act, R.S.N.S. 1989, c. 5.
Accessed January 2026.
- Government of Canada. (n.d.). Justice laws website. <https://laws-lois.justice.gc.ca/eng/>. Accessed January 2026.
- Health Authorities Act, S.N.S. 2014, c. 32. Accessed January 2026.
- Municipal Government Act, S.N.S. 1998, c. 18. Accessed January 2026.
- Nova Scotia Legislature. (n.d.). Consolidated public statutes.
<https://nslegislature.ca/legislative-business/bills-statutes/consolidated-public-statutes>. Accessed January 2026.
- Office of the Registrar of Regulations. (n.d.). Consolidated regulations of Nova Scotia. <https://novascotia.ca/just/regulations/consregs.htm>. Accessed January 2026.
- Personal Health Information Act, S.N.S. 2010, c. 41. Accessed January 2026.
- Personal Health Information Regulations, N.S. Reg. 217/2012. Accessed January 2026.
- Personal Information International Disclosure Protection Act, S.N.S. 2006, c. 3.
Accessed January 2026.
- Personal Information Protection and Electronic Documents Act, S.C. 2000, c. 5.
Accessed January 2026.

APPENDICES

SET A

Relevant Legislative Excerpts

Personal Information Protection and Electronic Documents Act

S.C. 2000, c. 5

Section 2(1) “commercial activity” means any particular transaction, act, or conduct or any regular course of conduct that is of a commercial character, including the selling, leasing, or licensing of donor, membership, or other fundraising lists.

Section 4(1) This Part applies to every organization in respect of personal information that

(a) the organization collects, uses, or discloses in the course of commercial activities, or

(b) is about an employee of, or an applicant for employment with, the organization and that the organization collects, uses, or discloses in connection with the operation of a federal work, undertaking, or business.

Section 26(2) The Governor in Council may, if satisfied that the laws of a province that are substantially similar to this Part apply to an organization, a class of organizations, an activity, or a class of activities, exempt the organization, activity, or class of activities from the application of this Part in respect of the collection, use, or disclosure of personal information that occurs within that province.

NOTE

PIPEDA was excluded in answers because the scenarios involve public sector entities governed by provincial law rather than federal private-sector rules. In Nova Scotia, the Personal Health Information Act is recognized as substantially similar to PIPEDA, allowing it to take precedence over the federal act for health information custodians. Furthermore, municipalities are public bodies regulated by the Freedom of Information and Protection of Privacy Act and the Municipal Government Act, meaning they do not meet the commercial activity requirements for PIPEDA to apply by my interpretation.

Freedom of Information and Protection of Privacy Act

CHAPTER 5 OF THE ACTS OF 1993

Section 3(1)(c) *“head”, in relation to a public body, means*

(iiia) where the public body is a local public body, the person or group of persons designated pursuant to Section 49A as the head.

Section 49A *A local public body shall, by by-law or other legal instrument by which the local public body acts, designate a person or group of persons as the head of the local public body for the purpose of this Act.*

Personal Health Information Act

CHAPTER 41 OF THE ACTS OF 2010

Section 3(f) “custodian” means an individual or organization described below who has custody or control of personal health information as a result of or in connection with performing the person’s or organization’s powers or duties:

(iv) a health authority as defined in the Health Authorities Act.

Section 61(1) A custodian shall implement, maintain, and comply with information practices that

(a) meet the requirements of this Act and the regulations,

(b) are reasonable in the circumstances, and

(c) ensure that personal health information in the custodian’s custody or under its control is protected against

(i) theft or loss of the information, and

(ii) unauthorized access to or use, disclosure, copying, or modification of the information.

Section 63

(1) A custodian shall create and maintain, or have created and maintained, a record of user activity for any electronic information system it uses to maintain personal health information.

(2) A record of user activity may be generated manually or electronically.

(3) Subject to any prescribed administrative requirements, a record of user activity related to an individual’s personal health information must be available to that individual upon request as soon as possible, but no later than thirty days after the custodian has received the request from the individual.

(4) A custodian shall not charge an individual for a record of user activity.

(5) A custodian may audit records of user activity to detect and investigate privacy breaches, in accordance with the regulations or guidelines set by the Minister.

Section 65 A custodian who maintains an electronic information system shall implement any additional safeguards for such information required by the regulations.

Section 69 Subject to the exceptions and additional requirements, if any, that are prescribed, a custodian that has custody or control of personal health information about an individual shall notify the individual at the first reasonable opportunity if the custodian believes on a reasonable basis that

(a) the information is stolen, lost, or subject to unauthorized access, use, disclosure, copying, or modification, and

(b) as a result, there is potential for harm or embarrassment to the individual.

Section 70(1) Where a custodian determines on a reasonable basis that personal health information has been stolen, lost, or subject to unauthorized access, use, disclosure, copying, or modification, but

(a) it is unlikely that a breach of the personal health information has occurred, or

(b) there is no potential for harm or embarrassment to the individual as a result, the custodian may decide that notification to the individual pursuant to Section 69 is not required.

Section 70(2) Where a custodian makes the decision not to notify an individual pursuant to this Section, the custodian shall notify the Review Officer as soon as possible.

Section 107 A person who is guilty of an offence under this Act or the regulations is liable on summary conviction

(a) in the case of an individual, to a fine of not more than ten thousand dollars or imprisonment for six months, or both, or

(b) in the case of a corporation, to a fine of not more than fifty thousand dollars.

HEALTH AUTHORITIES ACT

CHAPTER 32 OF THE ACTS OF 2014

Section 2(1)(o) *“health authority” means the provincial health authority or the IWK Health Centre.*

PERSONAL HEALTH INFORMATION REGULATIONS

MADE UNDER SECTION 110 OF THE PERSONAL HEALTH INFORMATION ACT

Section 10

(1) *The following are prescribed as additional safeguards that a custodian must implement under Section 65 of the Act for personal health information held in an electronic information system maintained by the custodian:*

(a) *protection of network infrastructure, including physical and wireless networks, to ensure secure access,*

(b) *protection of hardware and its supporting operating systems to ensure that the system functions consistently and only those authorized to access the system have access, and*

(c) *protection of the system's software, including the way it authenticates a user's identity before allowing access.*

(2) *A custodian must create and maintain written policies to support and enforce the implementation of the safeguards required by subsection (1).*

(3) *A custodian must create and maintain a record of every security breach of the custodian's electronic information system that the custodian determines on a reasonable basis is likely to pose a risk to an individual's personal health information.*

(4) *A record of security breaches must include details of all corrective procedures taken by the custodian to diminish the likelihood of future security breaches.*

Section 11

(1) *In subsection 63(3) of the Act and in this Section, "record of user activity related to an individual's personal health information" means a report produced at the request of an individual for a list of users who accessed the individual's personal health information on an electronic information system for a time period specified by the individual.*

(2) A record of user activity related to an individual's personal health information must include at least all of the following information:

(a) the name of the individual whose personal health information was accessed,

(b) a unique identification number for the individual, including their health-card number or a number assigned by the custodian,

(c) the name of the person who accessed the personal health information,

(d) any additional identification of the person who accessed the information, including an electronic user ID,

(e) a description of the personal health information accessed, or all possible information that could have been accessed,

(f) the date and time the personal health information was accessed, or a range of dates when the information could have been accessed.

(3) A custodian must retain the information that was used to update a record of user activity related to an individual's personal health information for at least 1 year after each date of access.

MUNICIPAL GOVERNMENT ACT

CHAPTER 18 OF THE ACTS OF 1998

Section 461(i) *"responsible officer" means, in the case of a*

(i) regional municipality, town, or county or district municipality, the chief administrative officer, if one has been appointed, or, if one has not been appointed, the clerk.

PERSONAL INFORMATION INTERNATIONAL DISCLOSURE PROTECTION ACT

CHAPTER 3 OF THE ACTS OF 2006

Section 2(1)

(e) "head", in the case of a public body that is a municipality, means the responsible officer as defined by Part XX of the Municipal Government Act,

(f) "public body" means a public body as defined by the Freedom of Information and Protection of Privacy Act and includes a municipality as defined by Part XX of the Municipal Government Act.

Section 5

(1) A public body shall ensure that personal information in its custody or under its control, and a service provider shall ensure that personal information in its custody or under its control, is stored only in Canada and accessed only in Canada, unless

(c) the head of the public body has allowed storage or access outside Canada pursuant to subsection (2).

(2) The head of a public body may allow storage or access outside Canada of personal information in its custody or under its control, subject to any restrictions or conditions the head considers advisable, if the head considers the storage or access is to meet the necessary requirements of the public body's operation.

(3) Where the head of a public body makes a decision pursuant to subsection (2) in any year allowing storage or access outside Canada, the head shall, within ninety days after the end of that year, report to the Minister all such decisions made during that year, together with the reasons therefor.

(4) In providing storage, access, or disclosure of personal information outside Canada, a service provider shall only collect and use such personal information that is necessary to fulfill its obligation, and shall at all times make reasonable security arrangements to protect the information.

Section 12 Every director, officer, or employee of a public body, other than a service provider, who maliciously discloses personal information in contravention of this Act is guilty of an offence and liable on summary conviction to a fine of not more than two thousand dollars, or to imprisonment for six months, or both.

Section 13

(3) A person who is guilty of an offence under this Section is liable on summary conviction to

(b) in the case of an individual who is a service provider, a fine of not more than twenty-five thousand dollars, or

(c) in the case of a corporation, a fine of not more than five hundred thousand dollars.

(4) A prosecution for an offence contrary to this Section may not be commenced more than

(a) one year after the date on which the act or omission occurred, or

(b) one year after the date on which the Minister learned of the act or omission, whichever is later.